

PENETRATION TESTING REPORT

Mediroza General Hospital

Black-Box Web Application Security Assessment

Engagement Detail	Value
Target	https://medirozahospital.com
Assessment Type	Authorized black-box web application penetration test
Assessment Objective	Identify and validate security weaknesses and document evidence
Scope	Authorized Mediroza Hospital web application/domain
Assessment Approach	Footprinting → Initial Access → Data Extraction → Critical Data Exposure → Reporting
Milestones	M1 Initial Access M2 Data Extraction M3 Critical Data Exposure M4 Reporting
Evidence	Screenshots supplied from the assessment workflow
Date	30 September – 1 October 2026

CONFIDENTIAL

This report contains security-test evidence and screenshots that may display sensitive information. Distribution should be limited to authorized recipients.

1. Executive Summary

An authorized black-box penetration test was performed against the Mediroza General Hospital web application. The assessment progressed through footprinting, controlled authentication testing, retrieval of protected laboratory reports, password recovery validation, and investigation of publicly exposed directories and a historical database backup.

Assessment outcome: The supplied evidence supports successful completion of M1 (Initial Access), M2 (Data Extraction), and M3 (Critical Data Exposure), followed by M4 reporting.

1.1 Principal Security Findings

ID	Finding	Severity	Milestone
F-01	SQL Injection / Authentication Bypass	Critical	M1
F-02	Publicly Accessible Historical Database Backup	Critical	M3
F-03	Weak Password Protection on Patient PDF Reports	High	M2
F-04	Directory Listing Enabled on Sensitive Paths	High	M3
F-05	Username / Authentication Information Disclosure	Medium	M1

1.2 Business Impact

- Unauthorized access to patient-facing functionality was demonstrated during the assessment.
- Three designated laboratory-report PDFs were obtained as part of the controlled assessment workflow.
- The supplied evidence demonstrates successful dictionary-based recovery of PDF passwords.
- A historical SQL database backup was publicly discoverable through the /old/ directory.
- The exposed backup contained staff records and a separate shareholder dataset, increasing the potential confidentiality impact.
- Directory listings exposed application filenames and paths, increasing reconnaissance value to an attacker.

2. Scope and Rules of Engagement

Category	Details
In Scope	Authorized Mediroza Hospital web application/domain
Testing Type	Black-box penetration testing
Social Engineering	Out of scope
Denial of Service	Out of scope
Third-Party Systems	Out of scope unless explicitly part of the authorized target
Evidence Handling	Screenshots and recovered evidence treated as confidential

The report is based on the screenshots supplied for the assessment. It does not infer vulnerabilities that are not supported by the supplied evidence.

3. Methodology

The assessment was organized around the user's milestone workflow and the supplied evidence:

Phase	Objective	Evidence Outcome
Footprinting	Collect publicly observable application and domain information	robots.txt, HTTP headers, WHOIS
M1 – Initial Access	Validate authentication and application access controls	Patient Portal test and access to reports
M2 – Data Extraction	Assess protection of retrieved documents	Password-recovery evidence and recovered reports
M3 – Critical Data Exposure	Identify exposed sensitive information and insecure directories	Database backup, patient/staff directories, staff/shareholder tables
M4 – Reporting	Document findings, evidence, impact, and remediation	This report

4. Footprinting / Reconnaissance

Footprinting was performed before exploitation to identify publicly observable information and application paths. The supplied screenshots show robots.txt contents, HTTP response headers, and WHOIS information.

4.1 Robots.txt Review

The robots.txt response disclosed references to /patient/, /staff/, and /old/. These paths were subsequently relevant to the assessment.

```
(kali@kali)-[~]
$ curl -s https://medirozahospital.com/robots.txt
# robots.txt
User-agent: *
Disallow: /patient/
Disallow: /staff/
Disallow: /old/
Sitemap: https://medirozahospital.com/sitemap.xml
```

Figure 1 — Footprinting evidence: robots.txt discloses /patient/, /staff/, and /old/ paths.

4.2 HTTP Response Headers

The supplied header capture records a successful HTTP response and identifies the web-server technology information visible in the response.

```
(kali@kali)-[~]
$ curl -i https://medirozahospital.com
HTTP/2 200
content-type: text/html
last-modified: Fri, 04 Sep 2026 02:03:12 GMT
accept-ranges: bytes
content-length: 5445
date: Thu, 01 Oct 2026 13:27:24 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed
```

Figure 2 — Footprinting evidence: HTTP response headers from the target.

4.3 WHOIS Information

WHOIS information was collected as part of domain-level footprinting. This provided registration and nameserver information visible through the WHOIS record.

```

(kali㉿kali)-[~]
$ whois medirozahospital.com
Domain Name: MEDIROZAHOSPITAL.COM
Registry Domain ID: 3132326963_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.namecheap.com
Registrar URL: http://www.namecheap.com
Updated Date: 2026-08-14T21:07:45Z
Creation Date: 2026-08-14T20:51:24Z
Registry Expiry Date: 2027-08-14T20:51:24Z
Registrar: NameCheap, Inc.
Registrar IANA ID: 1068
Registrar Abuse Contact Email: abuse@namecheap.com
Registrar Abuse Contact Phone: +1.6613102107
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransf
erProhibited
Name Server: DNS1.NAMECHEAPHOSTING.COM
Name Server: DNS2.NAMECHEAPHOSTING.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wi
cf/
>>> Last update of whois database: 2026-10-01T13:25:13Z <<<

For more information on Whois status codes, please visit https://icann.org/ep
p

NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiratio
n
date of the domain name registrant's agreement with the sponsoring
registrar. Users may consult the sponsoring registrar's Whois database to
view the registrar's reported date of expiration for this registration.

TERMS OF USE: You are not authorized to access or query our Whois
database through the use of electronic processes that are high-volume and
automated except as reasonably necessary to register domain names or
modify existing registrations; the Data in VeriSign Global Registry
Services' ("VeriSign") Whois database is provided by VeriSign for
information purposes only, and to assist persons in obtaining information
about or related to a domain name registration record. VeriSign does not
guarantee its accuracy. By submitting a Whois query, you agree to abide
by the following terms of use: You agree that you may use this Data only
for lawful purposes and that under no circumstances will you use this Data
to: (1) allow, enable, or otherwise support the transmission of mass
unsolicited, commercial advertising or solicitations via e-mail, telephone,
or facsimile; or (2) enable high volume, automated, electronic processes
that apply to VeriSign (or its computer systems). The compilation,
repackaging, dissemination or other use of this Data is expressly
prohibited without the prior written consent of VeriSign. You agree not to
use electronic processes that are automated and high-volume to access or
query the Whois database except as reasonably necessary to register
domain names or modify existing registrations. VeriSign reserves the right

```

Figure 3 — Footprinting evidence: WHOIS information for the target domain.

4.4 Additional robots.txt Capture

```
(kali@kali)-[~]
$ curl -s https://medirozahospital.com/robots.txt
# robots.txt
User-agent: *
Disallow: /patient/
Disallow: /staff/
Disallow: /old/

Sitemap: https://medirozahospital.com/sitemap.xml
```

Figure 4 — Additional capture of the robots.txt footprinting result.

5. M1 – Initial Access: SQL Injection / Authentication Testing

The first milestone focused on the patient portal authentication workflow. The supplied evidence shows a controlled SQL-injection-style input being entered into the username field and subsequent access to the patient-report area.

5.1 Authentication Test

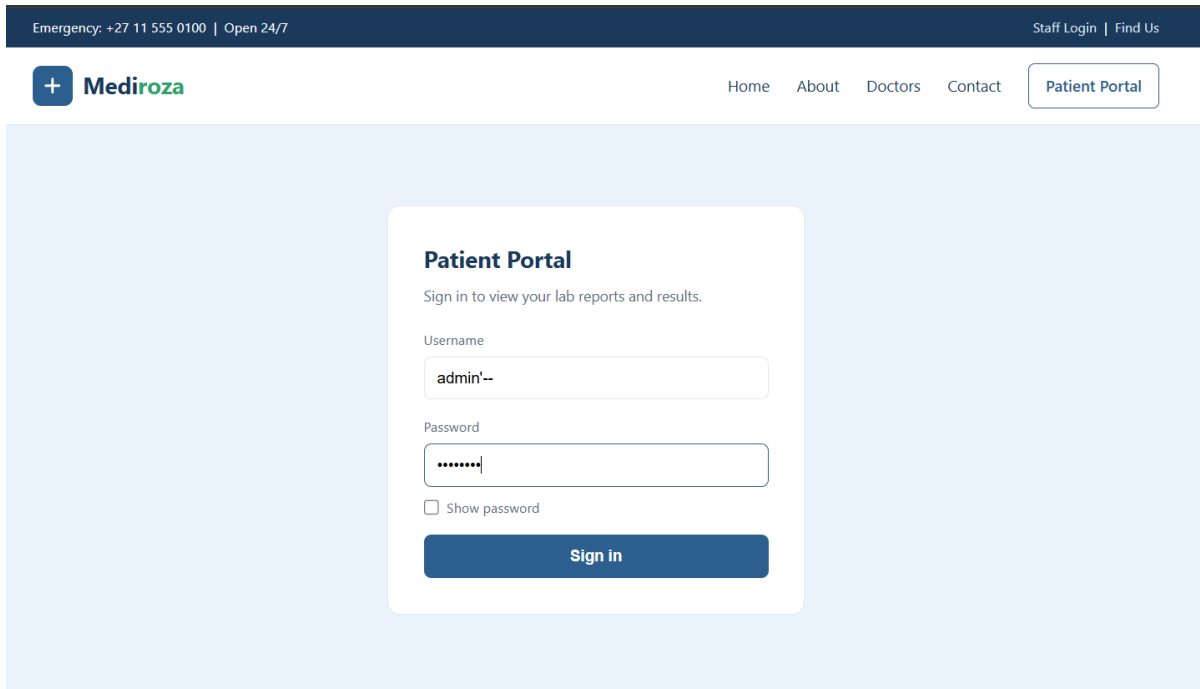


Figure 5 — Patient Portal screenshot showing the controlled authentication-input test.

5.2 Initial Access Result

Following the authentication test, the supplied evidence shows access to the authenticated patient-report interface. The page lists three password-protected pathology reports available for download.

My lab reports

Your reports are password protected. Use the password sent to you by the laboratory to open each file.

Pathology Report - S. Dlamini Lab Ref LR-2024-1187 2024-11-04 PDF (encrypted)	Download
Pathology Report - P. Reddy Lab Ref LR-2024-1192 2024-11-05 PDF (encrypted)	Download
Pathology Report - E. Thompson Lab Ref LR-2024-1205 2024-11-06 PDF (encrypted)	Download

Figure 6 — Authenticated patient-report page showing three protected pathology reports.

Finding F-01 – Critical: The supplied evidence supports an authentication weakness consistent with SQL injection leading to unauthorized access to authenticated functionality.

5.3 Security Impact

- Authentication controls can potentially be bypassed.
- Protected patient-report functionality became accessible.
- The vulnerability creates a pathway from an input-validation weakness to sensitive-data exposure.

5.4 Remediation

1. Use parameterized queries / prepared statements for all database operations.
2. Do not concatenate untrusted input into SQL statements.
3. Apply server-side input validation and centralized authentication controls.
4. Return generic authentication failure messages.
5. Add automated security regression tests for login and authentication endpoints.
6. Review application and database logs for evidence of exploitation.

6. M2 – Data Extraction: PDF Password Protection

After the patient-report area was accessed, the next milestone assessed the protection applied to the downloaded PDF documents. The supplied evidence shows successful dictionary-based password recovery against PDF files.

6.1 Password Recovery Evidence

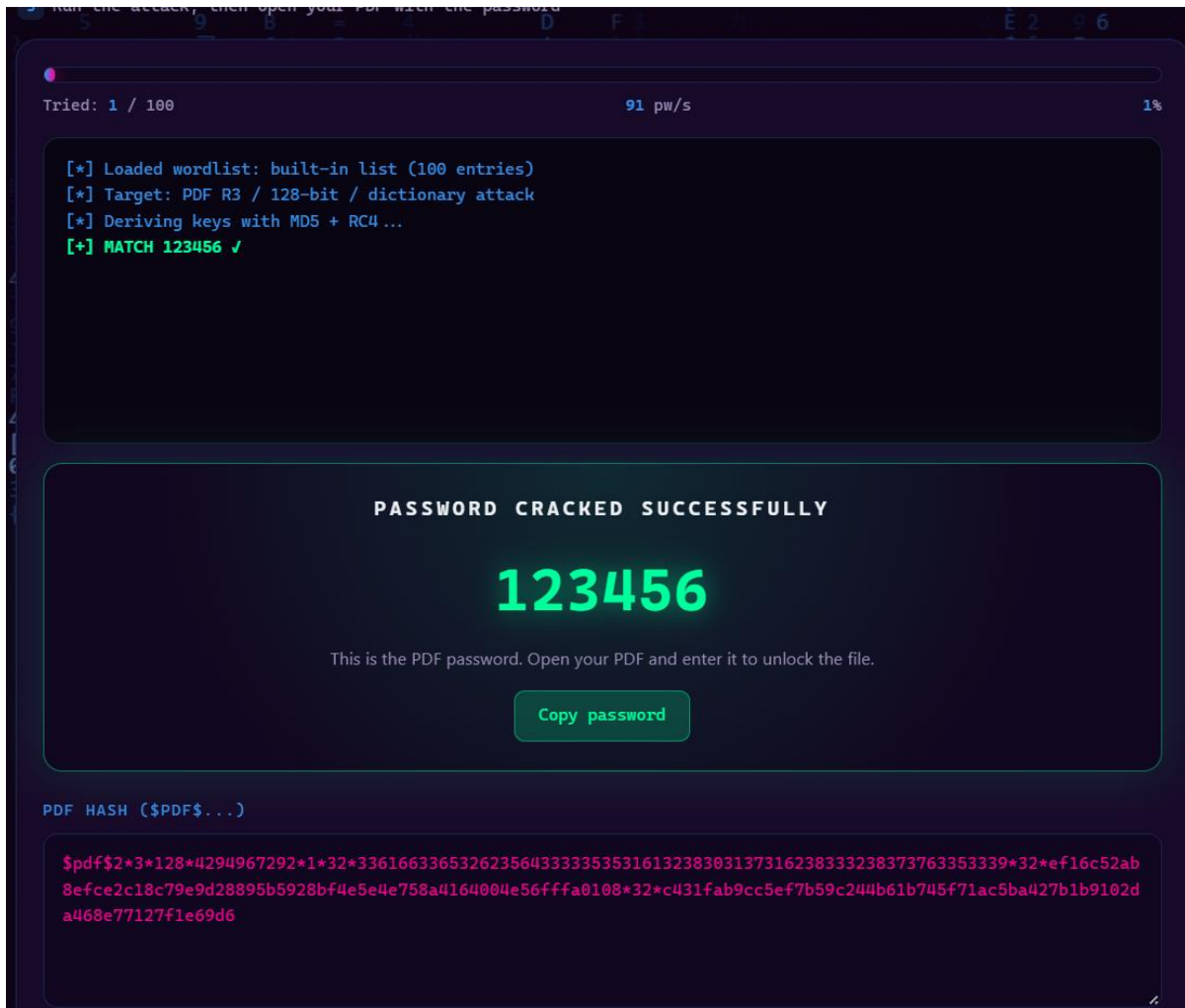


Figure 7 — Password-recovery evidence showing a successful dictionary match for a PDF.

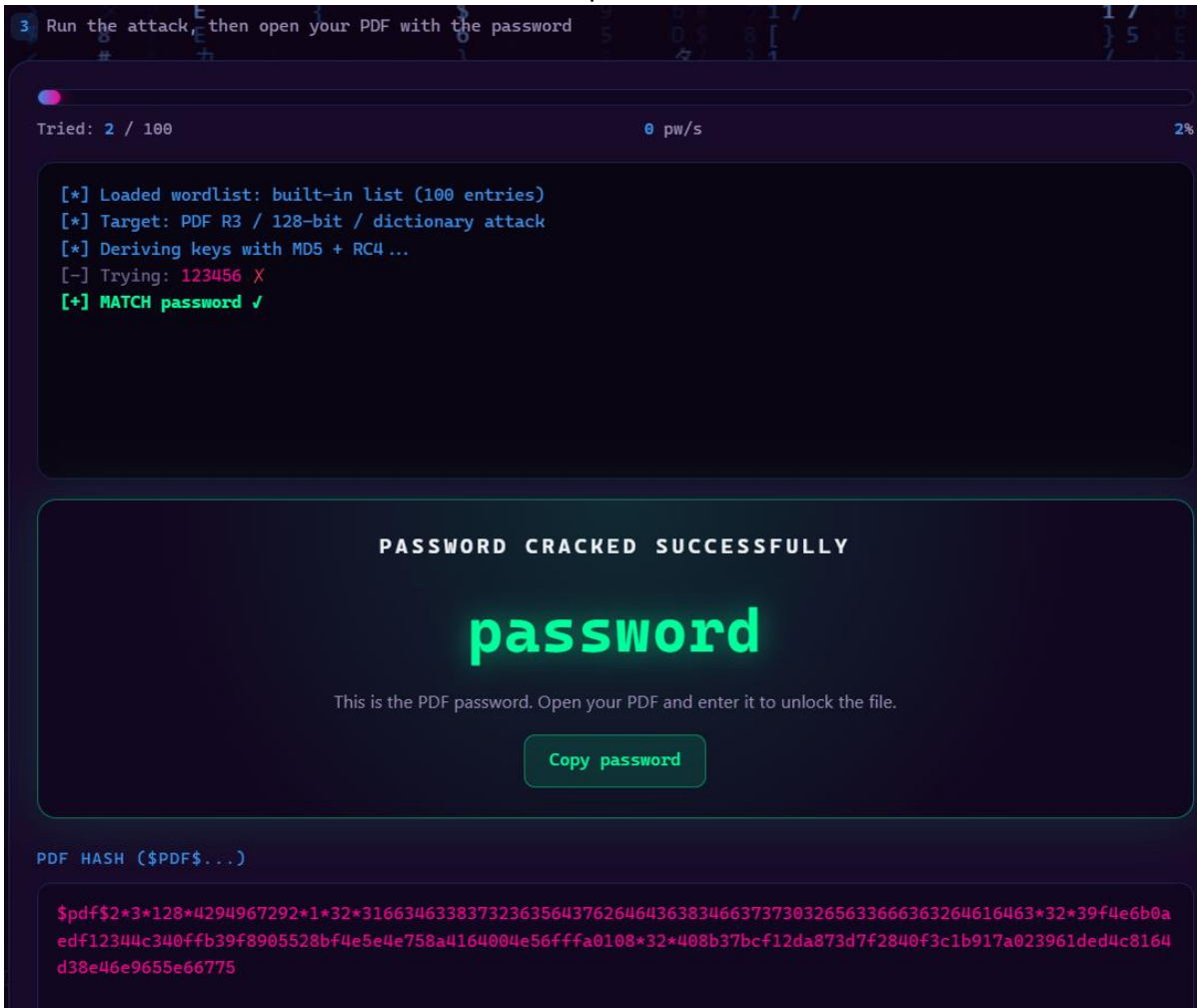


Figure 8 — Password-recovery evidence showing another successful dictionary match.

6.2 Recovered Report Evidence



Mediroza
General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT**CONFIDENTIAL**

Patient Name:

Sipho Dlamini

Patient ID:

MG-P-10231

Date of Birth:

1984-06-12

Gender:

Male

Report Date:

2024-11-04

Referring Dr:

Dr. Anita Naicker

Specimen:

Whole blood (EDTA)

Lab Ref No:

LR-2024-1187

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	x10 ⁹ /L	4.0 - 11.0	HIGH
Platelet Count	245	x10 ⁹ /L	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Figure 9 — Recovered pathology report evidence.



14 Cedar Avenue, Johannesburg, South Africa
Tel +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name: Priya Reddy Report Date: 2024-11-05
Patient ID: MG-P-10244 Referring Dr: Dr. Johan van der Merwe
Date of Birth: 1991-02-28 Specimen: Serum
Gender: Female Lab Ref No: LR-2024-1192

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

Reported by: Dr. Susan Botha, MBBCh FCPATH

Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)

This report is confidential and intended only for the named patient and the referring clinician.

Verified electronically. No signature required. Mediroza CMS 1.4.2

Figure 10 — Recovered pathology report evidence.

Finding F-03 – High: The supplied evidence demonstrates that the password protection applied to the retrieved PDFs was weak enough to be recovered through dictionary-based testing.

6.3 Security Impact

- PDF encryption provides limited protection when predictable or dictionary-based passwords are used.
- Once a protected document is acquired, password recovery can be performed offline.
- Sensitive laboratory information can therefore remain exposed despite the presence of PDF encryption.

6.4 Remediation

7. Use strong, randomly generated passwords where document-level encryption is required.
8. Avoid predictable, reused, or dictionary-based passwords.
9. Use modern document-encryption settings supported by the document-management platform.
10. Prefer authenticated portal access with authorization checks over directly downloadable sensitive documents.
11. Review existing sensitive PDFs and re-protect them using stronger controls.

7. M3 – Critical Data Exposure

M3 focused on identifying sensitive information exposed through publicly accessible directories and the historical database backup. The supplied screenshots demonstrate multiple independent exposure points.

7.1 Public /old/ Directory and Database Backup

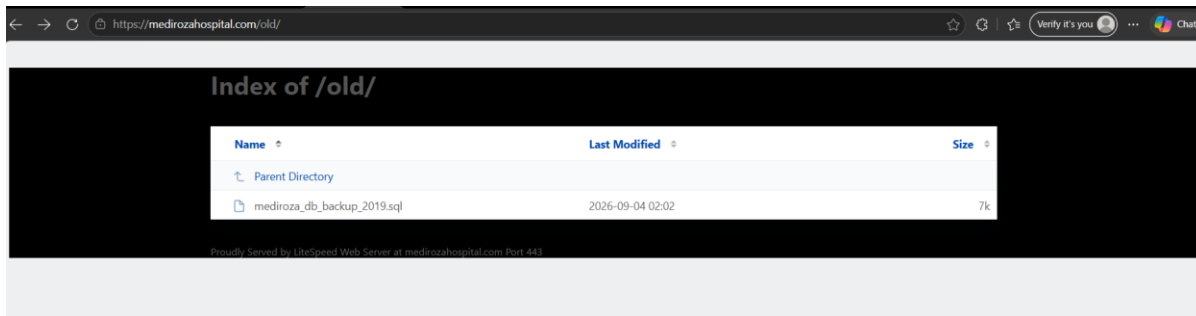


Figure 11 — Public /old/ directory exposing the historical SQL database backup.

The /old/ directory was accessible through the web application and exposed a historical SQL backup file. This represents a significant information-disclosure condition because database backups can contain large quantities of sensitive data.

Finding F-02 – Critical: A historical database backup was publicly accessible from a web directory.

7.2 Exposed Staff Database Information

```
-- Table structure for table `staff`
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary_zar` int(11) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

--
-- Dumping data for table `staff`
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 101 2007','85021013011081',138000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022082',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033083',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044084',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055085',128000,'2013-02-18'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','85071063066086',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077087',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088088',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099089',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110081',46000,'2017-10-02'),
(11,'Mowula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121082',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','85011123132083',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021133143084',35000,'2015-12-01'),
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','85031143154085',42000,'2013-03-25'),
(15,'Kgiso Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','85041153165086',61000,'2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051163176087',26000,'2019-02-14'),
(17,'Themba Nkosi','Radiographer','Radiology','t.nkosi@medirozahospital.com','+27 82 117 2119','85061173187088',44000,'2016-07-30'),
(18,'Palesa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198089',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193209081',41000,'2015-05-20'),
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091203220082',35000,'2018-08-06'),
(21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231083',130000,'2012-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111223242084',118000,'2013-10-17'),
(23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','85121233253085',48000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243264086',135000,'2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021253275087',52000,'2014-01-27'),
(26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263286088',29000,'2018-03-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273297089',27000,'2019-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051283308081',19000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061293319082',38000,'2015-08-24'),
(30,'Andile Mbeki','Ward Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2210','85071303330083',21000,'2019-11-05');
```

Figure 12 — Database backup evidence showing the staff table structure and stored staff-related fields.

The supplied database evidence shows a staff table containing fields for identity, employment information, contact information, identification information, salary-related information, and joining dates.

7.3 Exposed Shareholder Information

```
--
-- Table structure for table `shareholders`
--
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `shareholder_name` varchar(120) NOT NULL,
  `share_percent` decimal(5,2) NOT NULL,
  `shares_held` int(11) NOT NULL,
  `share_class` varchar(20) NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders` (`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
(4,'Reddy Family Trust',11.0,110000,'Ordinary'),
(5,'Thabo Molefe',10.0,100000,'Ordinary'),
(6,'Sarah Botha',9.0,90000,'Ordinary'),
(7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
(8,'Naledi Zulu',7.0,70000,'Ordinary'),
(9,'Michael Roberts',6.0,60000,'Ordinary'),
(10,'Dr. Vikram Chetty',4.0,40000,'Preferential');
UNLOCK TABLES;

SET FOREIGN_KEY_CHECKS = 1;
-- End of backup
```

Figure 13 — Database backup evidence showing the shareholders table and ownership-related fields.

The supplied evidence also shows a separate shareholders table containing ownership-related records.

7.4 Patient Directory Listing

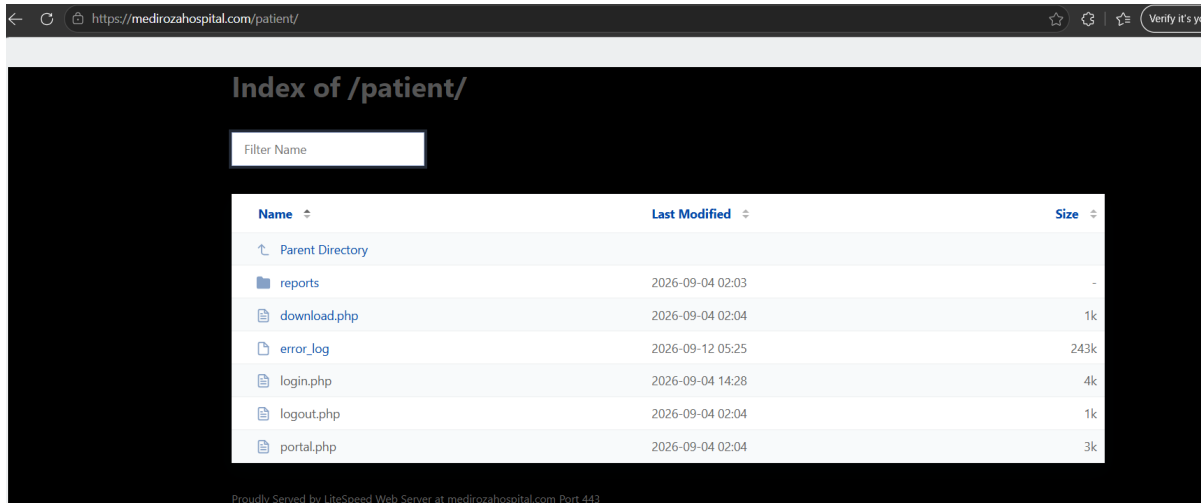


Figure 14 — /patient/ directory listing exposing application files, including authentication and report-related components.

The patient directory listing exposes application filenames and an error log. Directory indexing increases reconnaissance value and can reveal implementation details that should not normally be publicly browsable.

7.5 Staff Directory Listing

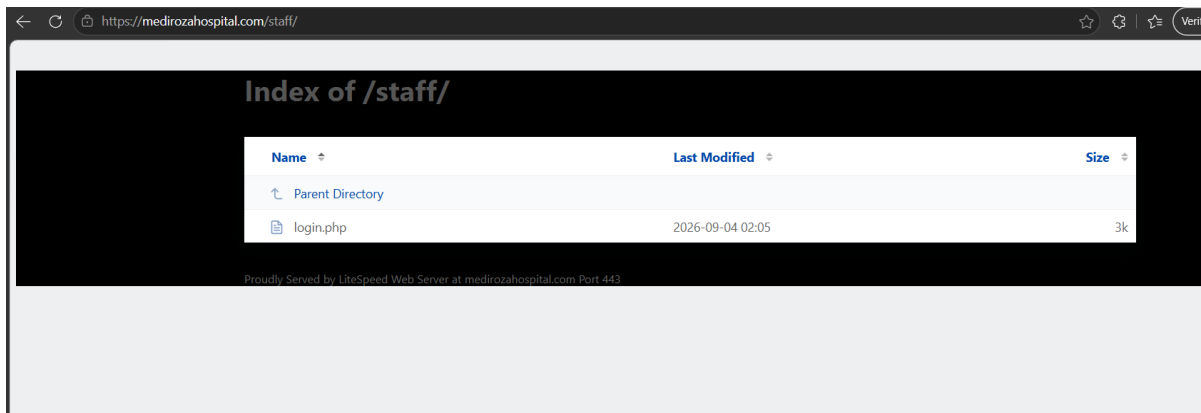


Figure 15 — /staff/ directory listing exposing the staff login endpoint.

The staff directory listing exposes the staff login endpoint directly. This provides an additional application path to an attacker performing reconnaissance.

Finding F-04 – High: Directory indexing was enabled on sensitive application paths, exposing filenames and increasing the observable attack surface.

7.6 M3 Security Impact

- Publicly accessible backups can expose historical application and database information.

- Sensitive staff and ownership records may be disclosed without authentication.
- Directory listings provide attackers with useful application paths and filenames.
- The exposure can amplify the impact of authentication and application-layer vulnerabilities.
- Sensitive information should be considered compromised within the scope of the authorized assessment evidence.

7.7 M3 Remediation

12. Remove database backups from the web document root.
13. Store backups outside web-accessible locations and restrict access using strong controls.
14. Disable directory indexing / autoindexing on all sensitive directories.
15. Remove obsolete files, logs, backups, and temporary artifacts from production web roots.
16. Scan deployments for .sql, .bak, .old, .backup, .zip, and similar artifacts.
17. Encrypt sensitive backups and enforce secure backup-retention procedures.
18. Review logs for access to exposed backup and directory paths.
19. Rotate credentials, secrets, or keys if they may have been present in exposed backup material.

8. Additional Finding – Authentication Information Disclosure

Finding F-05 – Medium: The assessment workflow identified authentication-related information disclosure during testing. This can assist subsequent credential-focused attacks when combined with other weaknesses.

8.1 Remediation

20. Use consistent, generic authentication failure messages.
21. Avoid revealing whether a submitted username exists.
22. Normalize relevant response behavior where practical.
23. Monitor and rate-limit repeated authentication discovery attempts.

9. Consolidated Findings Summary

ID	Finding	Severity	Primary Impact	Recommended Priority
F-01	SQL Injection / Authentication Bypass	Critical	Unauthorized authenticated access	Immediate
F-02	Public Database Backup	Critical	Sensitive database disclosure	Immediate
F-03	Weak PDF Password Protection	High	Offline document access	High
F-04	Directory Listing	High	Application/path disclosure	High
F-05	Authentication Information Disclosure	Medium	Account discovery assistance	Planned

10. Attack-Path Reconstruction

Based strictly on the supplied evidence, the assessment can be represented as the following progression:

1. Footprinting identified publicly observable paths and technical information.

2. The patient authentication workflow was tested and an SQL-injection-style input was used.
3. Authenticated patient-report functionality was reached.
4. Three protected PDF reports were obtained for controlled testing.
5. Dictionary-based password recovery successfully recovered PDF passwords.
6. Public directory listings were identified on patient, staff, and old paths.
7. The /old/ directory exposed a historical SQL database backup.
8. The backup contained staff and shareholder datasets, demonstrating critical data exposure.

11. Milestone Completion

Milestone	Status	Evidence / Result
M1 – Initial Access	COMPLETED	Patient Portal authentication testing and access to patient-report functionality.
M2 – Data Extraction	COMPLETED	Three designated PDF reports obtained; password-recovery evidence supplied.
M3 – Critical Data Exposure	COMPLETED	Public backup and directory exposure; staff and shareholder data structures evidenced.
M4 – Reporting	COMPLETED	Findings, evidence, impact, and remediation consolidated into this report.

12. Overall Remediation Plan

12.1 Immediate

24. Remove the exposed SQL backup from all web-accessible directories.
25. Disable directory indexing on /patient/, /staff/, /old/, and similar paths.
26. Remediate SQL injection using parameterized database access.
27. Review and rotate credentials or secrets potentially contained in exposed backup data.
28. Restrict direct access to sensitive patient documents.

12.2 Short Term

29. Replace weak document passwords with strong, unpredictable protection.
30. Implement consistent authentication error handling.
31. Remove exposed logs and unnecessary application files from production directories.
32. Introduce automated security checks for backup-file and directory-index exposure.

12.3 Long Term

33. Adopt secure software-development lifecycle practices.
34. Conduct recurring web-application penetration tests.
35. Implement secure backup storage, retention, and destruction procedures.
36. Apply least privilege to application and database accounts.
37. Centralize security logging and monitoring.
38. Provide developer training on SQL injection, authentication, authorization, and sensitive-data protection.

13. Conclusion

The supplied evidence demonstrates a sequence of weaknesses that can materially increase the confidentiality risk of the Mediroza General Hospital web application. The assessment progressed from footprinting to initial access, document extraction, password-recovery validation, and critical data exposure.

The most significant evidence relates to the authentication weakness and the publicly accessible historical database backup. The directory listings and weak PDF passwords further increase the practical impact by making sensitive application components and documents easier to discover or access.

Remediation should begin with removal of exposed backup material, disabling directory indexing, and correcting the underlying SQL injection and authentication weaknesses.

14. Evidence Register

Figure	Phase	Evidence
1–4	Footprinting	robots.txt, HTTP headers, WHOIS, additional robots.txt capture
5–6	M1	Patient Portal authentication test and patient reports page
7–10	M2	PDF password-recovery evidence and recovered report screenshots
11–15	M3	Exposed database backup, staff/shareholder tables, patient/staff directory listings

15. Confidentiality and Evidence Handling

This report contains screenshots that may display personal, medical, employment, salary, or ownership information. The evidence is included solely to document the authorized security assessment. It should be stored securely, shared only with authorized stakeholders, and deleted or retained according to the applicable assessment and data-retention requirements.

The findings and conclusions in this report are limited to the evidence supplied for this assessment. The presence of a screenshot demonstrates the observed condition at the time of testing; it does not establish that the condition remains present after remediation.